CIA Part 1 – Questions 237–295

Impossible-Level: Every Option Defensible, One Correct

CIA Study Prep

October 17, 2026

Instructions

Each question slide is followed by a separate answer/explanation slide.

Every option is designed to be defensible; the correct answer turns on a precise Standards priority or a single word.

Read every qualifier (MOST, LEAST, FIRST, BEST, PRIMARY) before answering.

Do not advance until you have committed to an answer.

Q237

Question: A CAE has functional reporting to the audit committee and administrative reporting to the CEO. The CEO's compensation is tied to a metric that internal audit is currently auditing. The CEO tells the CAE that the audit "must conclude the metric is reliable" before the compensation committee meets next week. The audit committee chair is on vacation and unreachable. Which is the MOST appropriate FIRST action?

A. Complete the audit objectively and report results to the audit committee when the chair returns, documenting the CEO's instruction.

B. Escalate immediately to another audit committee member or the full board because the CEO's instruction is a direct threat to objectivity and the chair is unavailable.

C. Delay the audit until the chair returns to avoid conflict with the CEO.

D. Remove the CEO's compensation metric from the audit scope to eliminate the conflict.

Q237 – Answer & Explanation

Correct Answer: B

Why: A direct instruction to reach a predetermined conclusion is an intimidation/self-interest threat requiring immediate escalation. The chair's unavailability does not permit delay when another committee member or the full board can receive the matter (Standards 1110/1130/2600). Completing the audit and reporting later (A) is defensible but leaves the threat unaddressed during a time-sensitive compensation decision; the FIRST action is escalation.

A wrong: Documents but does not neutralize the threat before the compensation decision.

C wrong: Delay cedes the engagement to CEO pressure.

D wrong: Narrowing scope to avoid conflict is improper (Standard 1130).

Q238

Question: An auditor is testing revenue at a company that recognizes revenue on "bill-and-hold" arrangements. The contracts state the customer requested the arrangement for its own storage reasons, the customer has a fixed obligation to pay, and the goods are segregated and ready for delivery. However, the customer's warehouse is owned by the company's CEO, and the customer has not taken physical delivery for 11 months. Which conclusion is MOST appropriate?

A. Revenue recognition is appropriate because all bill-and-hold criteria appear met.

B. Revenue recognition is likely inappropriate; the CEO-owned warehouse and 11-month non-delivery indicate the arrangement may lack genuine customer request and substantive business purpose.

C. Revenue recognition is appropriate because the customer has a fixed obligation to pay.

D. The auditor should accept the arrangement because bill-and-hold is permitted under accounting standards.

Q238 – Answer & Explanation

Correct Answer: B

Why: Bill-and-hold requires a genuine customer request and substantive business purpose. A CEO-owned warehouse and 11-month non-delivery suggest the arrangement is a sham to accelerate revenue. Fixed obligation and segregation do not cure the related-party/substance issue.

A wrong: Criteria appear met only on the surface; substance is contradicted.

C wrong: Fixed obligation alone is insufficient.

D wrong: Permitted arrangements can still be abused; the auditor must assess substance.

Q239

Question: The CAE is assessing the internal audit activity's conformance. The activity has: (1) a board-approved charter; (2) a risk-based plan; (3) no QAIP; (4) an engagement that audited a process the engagement partner designed; and (5) a CAE who reports functionally to the audit committee. The CAE wants to conclude "generally conforms." Which issue MOST directly precludes that conclusion?

A. The absence of a QAIP.

B. The self-review engagement (auditing a process the partner designed).

C. The risk-based plan.

D. The functional reporting to the audit committee.

Q239 – Answer & Explanation

Correct Answer: A

Why: Both the absence of a QAIP (Standards 1300–1312) and the self-review engagement (Standard 1130.A1) are nonconformances. However, the QAIP is a mandatory, activity-wide requirement; its complete absence means the activity cannot "generally conform" regardless of engagement-level issues. The self-review is an engagement-level nonconformance that could be isolated. This is the nuance: the QAIP gap is systemic, the self-review is engagement-specific.

B wrong: A serious nonconformance, but engagement-specific; the systemic QAIP gap is the more direct preclusion.

C wrong: Risk-based plan is a strength.

D wrong: Functional reporting is a strength.

Q240

Question: An auditor is evaluating a whistleblower complaint alleging that the CFO directed the company to "round up" revenue estimates. The complaint was made to the hotline, which is managed by the general counsel, who reports to the CFO. The general counsel tells the auditor the complaint is "unfounded" and closes it without investigation. Which is the MOST significant control weakness?

A. The complaint was anonymous.

B. The hotline's reporting line to the general counsel, who reports to the CFO, creates a conflict that allows suppression of a complaint about the CFO.

C. The complaint alleged rounding up revenue estimates.

D. The general counsel closed the complaint.

Q240 – Answer & Explanation

Correct Answer: B

Why: The root weakness is structural: the hotline reports to an executive who reports to the subject of the complaint, enabling suppression. C and D are symptoms; A is irrelevant. The auditor must report the structural flaw and the suppression.

A wrong: Anonymity is a feature, not a weakness.

C wrong: The allegation is the trigger, not the weakness.

D wrong: Closing without investigation is a symptom of the structural conflict.

Q241

Question: An auditor is testing the completeness of accounts payable. The auditor performs a search for unrecorded liabilities by reviewing cash disbursements after year-end. The auditor finds that a $2 million payment made in January related to December goods received was recorded as a January expense, not a December liability. Management states the amount is "immaterial" (0.8% of net income). Which is the MOST appropriate conclusion?

A. The matter is immaterial and should not be reported.

B. The matter is a control deficiency (completeness of payables) and may be qualitatively material because it affects period-to-period comparability and could indicate a pattern; it should be reported and evaluated.

C. The auditor should ignore the matter because cash disbursements were reviewed.

D. The auditor should adjust the financial statements personally.

Q241 – Answer & Explanation

Correct Answer: B

Why: Quantitative immateriality does not end the analysis; qualitative factors (pattern, comparability, control weakness) matter. The auditor must report the control deficiency and evaluate qualitative materiality.

A wrong: Immateriality is not purely quantitative.

C wrong: Reviewing disbursements is the test that found the issue; ignoring it is improper.

D wrong: Internal audit does not adjust financial statements.

Q242

Question: The CAE is asked by the audit committee to assess whether the CEO's expense reimbursements are appropriate. The CEO approves the CAE's budget and has previously threatened to "restructure" internal audit if findings about executives were reported. The audit committee chair assures the CAE that "the committee will back you." Which is the MOST appropriate action?

A. Decline because the CEO's budget control and threat impair independence.

B. Accept, document the threat, ensure the audit committee receives results directly, and consider assigning a strong engagement team to reduce dependence on the CEO.

C. Accept but report findings only verbally to the chair.

D. Accept and exclude the CEO's travel expenses from scope.

Q242 – Answer & Explanation

Correct Answer: B

Why: The audit committee provides functional oversight and has committed support; safeguards (direct reporting, documentation, competent team) mitigate the threat. Standards 1110/1130/2600 support accepting with safeguards rather than declining.

A wrong: Declining leaves a governance-requested engagement undone; safeguards can mitigate.

C wrong: Verbal-only reporting is not an appropriate communication channel.

D wrong: Excluding the CEO's travel from scope defeats the engagement.

Q243

Question: An auditor is testing a key control that requires the controller to review and sign a monthly bank reconciliation. The auditor finds that the controller signed all 12 reconciliations but that the reconciliations were prepared by the controller's spouse, who is the assistant controller, and that the spouse also has system access to post adjusting entries. Which is the MOST significant weakness?

A. The controller signed all 12 reconciliations.

B. The preparer (spouse) also has system access to post adjusting entries and is reviewed by the controller, creating a familial self-review and segregation weakness.

C. The reconciliations were monthly.

D. The assistant controller is a spouse.

Q243 – Answer & Explanation

Correct Answer: B

Why: The most significant weakness is the combination: the preparer can post adjusting entries (custody/record-keeping) and is reviewed by a close family member (impaired review). This defeats segregation and independent review.

A wrong: Signing is the review; the issue is the reviewer's independence.

C wrong: Monthly frequency is appropriate.

D wrong: The relationship alone is not the weakness; the combination with posting access and review is.

Q244

Question: An auditor is evaluating a third-party administrator (TPA) for a pension plan. The TPA has a SOC 1 Type II report with no exceptions, but the report's period ended 10 months ago and the TPA has since changed its subservice provider for benefit calculations. The organization has no right to audit the TPA. Which is the MOST appropriate conclusion?

A. The SOC 1 report is sufficient because it is Type II with no exceptions.

B. Reliance is limited; the report is stale, the subservice provider changed, and the organization lacks audit rights, creating significant third-party risk.

C. The organization should terminate the TPA immediately.

D. SOC reports are not relevant to pension plans.

Q244 – Answer & Explanation

Correct Answer: B

Why: A Type II report is useful but not sufficient when stale, when subservice providers changed, and when audit rights are absent. Reliance is limited and the risk must be reported.

A wrong: No-exception status does not cure staleness or changes.

C wrong: Termination is an overreaction.

D wrong: SOC reports are relevant to pension administration.

Q245

Question: The CAE is evaluating whether to rely on the work of an external consultant who performed a cybersecurity maturity assessment. The consultant is highly qualified, was engaged by the CIO, used a recognized framework, and concluded the organization is "mature." The CIO is the sponsor of the cybersecurity program being assessed. Which factor MOST limits reliance?

A. The consultant's qualifications.

B. The consultant's objectivity, given engagement by the CIO who sponsors the program being assessed.

C. The recognized framework used.

D. The conclusion of "mature."

Q245 – Answer & Explanation

Correct Answer: B

Why: Standard 2050 requires evaluating objectivity and competence. Engagement by the program sponsor creates a self-interest/self-review threat that most limits reliance, even with qualifications and a recognized framework.

A wrong: Qualifications support reliance.

C wrong: A recognized framework supports reliance.

D wrong: The conclusion itself is not the limiting factor; objectivity is.

Q246

Question: An auditor is testing the organization's controls over the financial close. The controller has the ability to post manual entries and then "hide" them from the standard ledger view. The controller used this 9 times in the year; all entries increased revenue and reduced reserves, all were reversed in the following year, and all lacked support. The CFO states the entries were "quarter-end estimates." Which is the MOST appropriate conclusion and action?

A. Controls are effective because the entries were reversed in the following year.

B. Controls are deficient and the pattern is a serious fraud indicator (hidden entries, revenue increase, reserve reduction, no support, reversal); preserve evidence, escalate, and recommend investigation.

C. The auditor should accept the CFO's explanation because quarter-end estimates are common.

D. The auditor should report only the system configuration weakness and not the entries.

Q246 – Answer & Explanation

Correct Answer: B

Why: Hidden entries increasing revenue, reducing reserves, lacking support, and reversed are classic earnings-management/fraud indicators (cookie-jar reserves, improper estimates). Reversal does not legitimize them.

A wrong: Reversal does not cure the improper recognition.

C wrong: Common estimates do not explain hidden, unsupported, revenue-increasing entries.

D wrong: Reporting only the configuration ignores the substance.

Q247

Question: An auditor discovers that the organization's treasury department has been using a single counterparty for all foreign exchange hedges. The counterparty is owned by the treasurer's brother, and hedge pricing is consistently 2–3% worse than market. The treasurer states the pricing is "within tolerance." Which is the MOST appropriate conclusion?

A. Controls are effective because pricing is within tolerance.

B. Controls are deficient; related-party concentration and unfavorable pricing create significant fraud/conflict-of-interest risk requiring investigation and reporting.

C. The auditor should accept the treasurer's statement because he is accountable for treasury.

D. Related-party transactions are outside the scope of internal audit.

Q247 – Answer & Explanation

Correct Answer: B

Why: Single-counterparty concentration, a family relationship, and consistently unfavorable pricing are classic fraud/conflict-of-interest indicators. "Within tolerance" does not address the conflict.

A wrong: Tolerance does not cure the conflict.

C wrong: Accountability does not replace independent review.

D wrong: Related-party transactions are a core audit area.

Q248

Question: The CAE is evaluating whether the internal audit activity can rely on a specialist's work in a complex valuation engagement. The specialist is a qualified appraiser, was engaged by management, is independent of the auditee's operations, and used assumptions that management approved. Which factor MOST limits reliance?

A. The specialist's qualifications.

B. The specialist's independence from internal audit and the fact that management approved the assumptions.

C. The complexity of the valuation.

D. The cost of the specialist.

Q248 – Answer & Explanation

Correct Answer: B

Why: When relying on a specialist, the auditor must evaluate competence, objectivity, and the appropriateness of the specialist's assumptions. Management-approved assumptions and engagement by management create objectivity concerns that most limit reliance.

A wrong: Qualifications support reliance.

C wrong: Complexity is why a specialist is used.

D wrong: Cost is not a reliance criterion.

Q249

Question: An auditor is testing the organization's controls over the vendor master file. The auditor finds that 30 vendors share the same bank account, 12 of those were added by the same clerk, and 8 are registered at a virtual office address. The clerk states the vendors are "legitimate suppliers." Which is the MOST appropriate action?

A. Accept the clerk's explanation because the vendors are described as suppliers.

B. Investigate the vendors as a potential shell-company/kickback scheme, preserve evidence, and report through appropriate channels.

C. Remove the suspicious vendors from the master file personally.

D. Ignore the findings because virtual offices are common.

Q249 – Answer & Explanation

Correct Answer: B

Why: Shared bank accounts, a single clerk adding vendors, and virtual addresses are classic shell-company/kickback red flags. Investigate, preserve evidence, and report; do not alter records.

A wrong: Labels do not explain the red flags.

C wrong: Internal audit should not make management changes.

D wrong: Ignoring red flags is improper.

Q250

Question: The CAE is assessing the organization's risk management for a major acquisition. Management's integration plan addresses finance and operations but not culture, IT systems, or third-party contracts. The acquisition is the largest in the organization's history. Which conclusion is MOST appropriate?

A. Integration risk management is adequate because finance and operations are covered.

B. Integration risk management is deficient; culture, IT, and third-party contract risks are significant and unaddressed.

C. Acquisition integration is outside internal audit's scope.

D. The auditor should ignore culture because it cannot be measured.

Q250 – Answer & Explanation

Correct Answer: B

Why: Acquisition integration risk includes culture, IT, and third-party contracts, all of which can materially affect deal success. Omitting them is a significant gap.

A wrong: Partial coverage is not adequate for a major acquisition.

C wrong: Acquisition integration is a core audit area.

D wrong: Culture is a recognized integration risk.

Q251

Question: An auditor is evaluating the organization's controls over the use of spreadsheets for a critical regulatory capital calculation. The spreadsheet has documented formulas, version control, and independent review, but it is maintained by a single analyst with no backup, and the analyst is the only person who understands the model. Which conclusion is MOST appropriate?

A. Controls are effective because the spreadsheet has documented formulas, version control, and review.

B. Controls are partially effective but have a key-person risk; lack of backup and single-person knowledge threaten continuity and create operational risk.

C. Controls are fully effective because the analyst is experienced.

D. The auditor should not assess spreadsheet controls.

Q251 – Answer & Explanation

Correct Answer: B

Why: Documented formulas, version control, and review are positive, but single-person dependency and no backup create key-person and continuity risk for a critical regulatory calculation.

A wrong: Key-person risk undermines effectiveness.

C wrong: Experience does not eliminate key-person risk.

D wrong: Spreadsheet controls are a valid audit area.

Q252

Question: The CAE is asked by the audit committee to evaluate whether the organization's fraud risk assessment is "adequate." Management's assessment covers asset misappropriation and corruption but explicitly excludes financial statement fraud "because the external auditor covers that." Which is the MOST appropriate conclusion?

A. The assessment is adequate because the external auditor covers financial statement fraud.

B. The assessment is deficient; financial statement fraud is a management and internal audit responsibility and cannot be delegated to the external auditor.

C. Financial statement fraud is not a fraud risk.

D. The auditor should accept the exclusion because it is documented.

Q252 – Answer & Explanation

Correct Answer: B

Why: Financial statement fraud is a core fraud risk that management must assess and internal audit must consider (Standard 1210.A2). External audit does not eliminate management's responsibility.

A wrong: External audit coverage does not transfer management responsibility.

C wrong: Financial statement fraud is a recognized fraud category.

D wrong: Documentation does not make an omission adequate.

Q253

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q253 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q254

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q254 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q255

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q255 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q256

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q256 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q257

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q257 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q258

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q258 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q259

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q259 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q260

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q260 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q261

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q261 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q262

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q262 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q263

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q263 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q264

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q264 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q265

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q265 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q266

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q266 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q267

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q267 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q268

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q268 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q269

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q269 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q270

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q270 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q271

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q271 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q272

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q272 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q273

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q273 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q274

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q274 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q275

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q275 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q276

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q276 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q277

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q277 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q278

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q278 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q279

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q279 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q280

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q280 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q281

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q281 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q282

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q282 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q283

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q283 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q284

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q284 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q285

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q285 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q286

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q286 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q287

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q287 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q288

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q288 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q289

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q289 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q290

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q290 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q291

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q291 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q292

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q292 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q293

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q293 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q294

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q294 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q295

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q295 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

End

End of Questions 237–295

Review, repeat, and mark weak areas.